

LAPORAN PROGRES
MINGGU KE – 1
Mata Kuliah Secure Software Engineering



Dosen Pengampu :
Septian Geges, S.Kom., M.Kom.

Disusun Oleh :

Hessel Josef Imanuel	2330205030062
Apreldiovano Brian Walmaputra	2330305030089
Rafael Sanjaya	2330305030075
Yohanes Abel Kelvin	2330205030051

JURUSAN TEKNIK INFORMATIKA
FAKULTAS TEKNIK
UNIVERSITAS PALANGKA RAYA
2026

DAFTAR ISI

DAFTAR ISI	i
BAB I PENDAHULUAN	1
1.1 Gambaran Umum Pengerjaan	1
1.2 Tujuan Progress Minggu 1	1
BAB II PEMBAHASAN	2
2.1 Penyusunan Dokumen SRS-Sec	2
2.1.1 Deskripsi Sistem	2
2.1.2 Identifikasi Aset Kritis	3
2.1.3 Security Requirements	6
2.1.4 Definisi Stakeholder & Trust Boundary	9
2.2 Pembuatan DFD Level 0	12
2.3 Pembuatan DFD Level 1	12
2.4 Penyusunan Attack Tree	14
2.5 Analisis STRIDE	15
2.6 Perancangan Arsitektur Sistem	17
2.7 Persiapan Repository GitHub	18
BAB III PENUTUP	19
3.1 Kesesuaian dengan Target Minggu 1	19
3.2 Kendala yang Dihadapi	20
3.3 Rencana Tindak Lanjut Minggu Berikutnya	20
3.4 Kesimpulan	20
3.5 Lampiran	21

BAB I

PENDAHULUAN

1.1 Gambaran Umum Pengerjaan

Pada proyek ini, kelompok mengembangkan rancangan awal Hotel Booking Secure System, yaitu sistem booking hotel berbasis web yang berfokus pada aspek fungsional dan keamanan. Sistem ini dirancang agar dapat digunakan oleh dua jenis pengguna, yaitu tamu sebagai pengguna akhir dan admin sebagai pengelola sistem. Tamu dapat melakukan registrasi, login, pencarian kamar, booking, pembayaran, dan melihat riwayat booking. Sementara itu, admin dapat mengelola data kamar, data booking, serta melihat laporan transaksi.

Fokus utama pada minggu pertama adalah menyusun kebutuhan sistem, memetakan alur data, mengidentifikasi batas kepercayaan sistem, serta melakukan analisis awal terhadap potensi ancaman keamanan. Berdasarkan dokumen SRS-Sec yang telah disusun, sistem ini menggunakan teknologi HTML, CSS, dan JavaScript pada sisi frontend, PHP pada sisi backend, MySQL sebagai database, serta integrasi eksternal dengan Payment Gateway untuk proses pembayaran. Oleh karena itu, sejak tahap awal perancangan diperlukan analisis kebutuhan sistem, pemetaan alur data, identifikasi aset kritis, serta analisis ancaman keamanan.

1.2 Tujuan Progress Minggu 1

Tujuan pengerjaan pada minggu pertama adalah untuk menghasilkan dasar perancangan sistem yang jelas sebelum masuk ke tahap implementasi. Adapun tujuan khusus dari progress minggu pertama adalah sebagai berikut:

1. Menyusun dokumen Software Requirements Specification Security Requirements Document (SRS-Sec).
2. Membuat DFD Level 0 sebagai gambaran umum sistem.
3. Membuat DFD Level 1 untuk menjelaskan proses sistem secara lebih rinci.
4. Menyusun Attack Tree untuk mengidentifikasi kemungkinan jalur serangan terhadap sistem.
5. Melakukan analisis ancaman menggunakan metode STRIDE.
6. Membuat rancangan arsitektur sistem dan pemetaan trust boundary.
7. Menyiapkan struktur folder proyek dan repository GitHub sebagai tempat dokumentasi dan pengembangan sistem.

BAB II

PEMBAHASAN

2.1 Penyusunan Dokumen SRS-Sec

Pada tahap awal, kelompok menyusun dokumen SRS-Sec untuk mendefinisikan kebutuhan fungsional dan kebutuhan keamanan sistem. Dokumen ini memuat deskripsi sistem, identifikasi aset kritis, kebutuhan keamanan seperti autentikasi, otorisasi, keamanan data, validasi input, keamanan pembayaran, logging, serta definisi stakeholder & trust boundary. Berikut rincian dari dokumen SRS – Sec.

2.1.1 Deskripsi Sistem

Hotel Booking Secure System adalah sistem pemesanan hotel berbasis web yang digunakan untuk membantu pengguna dalam melakukan registrasi akun, login, pencarian kamar, booking kamar, pembayaran, serta melihat riwayat pemesanan. Sistem ini dibangun menggunakan beberapa komponen teknologi, yaitu HTML, CSS, dan JavaScript pada bagian frontend yang berjalan di browser, PHP sebagai backend, MySQL sebagai database, serta payment gateway sebagai layanan eksternal untuk memproses pembayaran. Sistem ini memiliki beberapa pihak yang terlibat, yaitu Tamu/User sebagai pengguna akhir, Admin sebagai pengelola sistem, Payment Gateway sebagai pihak eksternal pemroses pembayaran, dan Developer sebagai tim yang bertanggung jawab dalam pengembangan, pengujian, serta pemeliharaan sistem.

Alur data pada sistem dimulai dari Tamu/User yang melakukan registrasi dengan mengirimkan data seperti nama, email, dan password. Sistem kemudian memvalidasi input, melakukan hashing password, menyimpan data pengguna ke database, lalu menampilkan status registrasi berhasil atau gagal. Setelah itu, pengguna dapat login menggunakan email dan password. Sistem akan memvalidasi kredensial melalui proses Login/Register, mencocokkan password dengan password hash pada database, lalu membuat session atau token autentikasi apabila data valid. Setelah berhasil login, pengguna dapat melakukan pencarian kamar dengan memasukkan tanggal menginap, tipe kamar, dan jumlah kamar. Sistem akan memvalidasi input pencarian, mengambil data ketersediaan kamar dan harga dari database, kemudian menampilkan hasil pencarian kamar yang tersedia.

Selanjutnya, pengguna dapat melakukan booking kamar dengan memilih kamar dan mengirimkan detail booking seperti tanggal, tipe kamar, jumlah tamu,

serta metode pembayaran. Sistem akan memvalidasi data booking di sisi server, memeriksa ketersediaan kamar, menyimpan data booking ke database, lalu memberikan konfirmasi berupa ID booking. Pada proses pembayaran, sistem membuat permintaan transaksi ke payment gateway, kemudian payment gateway memproses pembayaran dan mengirimkan callback status pembayaran ke sistem. Sistem akan memverifikasi signature, timestamp, nominal pembayaran, dan ID booking sebelum memperbarui status transaksi pada database. Di sisi admin, admin dapat login ke dashboard setelah sistem memvalidasi akun dan role admin. Admin dapat mengelola data kamar, mengelola data booking, melihat laporan transaksi, serta memantau log aktivitas sistem. Setiap aktivitas penting seperti login, booking, pembayaran, callback payment gateway, dan perubahan data akan dicatat ke audit log tanpa menyimpan data sensitif seperti password, token, API key, atau informasi kartu pembayaran.

2.1.2 Identifikasi Aset Kritis

Tabel 2.1 Identifikasi Aset Kritis Sistem

ID Aset	Nama Aset	Lokasi / Proses Terkait	Tingkat Risiko	Alasan Kritis
A-001	Kredensial login pengguna	P1.0 Login/Register, DS1 Db.Users	Kritis	Jika bocor, akun pengguna dapat diambil alih oleh pihak tidak sah.
A-002	Password hash	DS1 Db.Users	Kritis	Password harus disimpan dalam bentuk hash aman agar tidak terbaca langsung jika database bocor.
A-003	Data pribadi tamu	DS1 Db.Users	Kritis	Berisi informasi pengguna seperti nama, email, dan kontak yang bersifat sensitif.

A-004	Session token / cookie	Proses login dan manajemen sesi	Tinggi	Jika dicuri, penyerang dapat melakukan session hijacking dan masuk tanpa password.
A-005	Data booking	P2.0 Booking Kamar, DS2 Db.Booking	Tinggi	Manipulasi data booking dapat menyebabkan double booking, perubahan harga, atau status tidak valid.
A-006	Data transaksi pembayaran	P3.0 Pembayaran, DS3 Db.Transaksi	Kritis	Berkaitan langsung dengan pendapatan hotel dan validitas transaksi.
A-007	Status pembayaran	P3.0 Pembayaran, DS3 Db.Transaksi	Kritis	Status pembayaran yang dimanipulasi dapat menyebabkan booking dianggap lunas secara tidak sah.
A-008	Database sistem	DS1, DS2, DS3	Kritis	Menyimpan seluruh data penting sistem, termasuk user, booking, dan transaksi.
A-009	File konfigurasi	Backend server, .env, config.php	Kritis	Dapat berisi credential database, API key, dan secret payment gateway.

A-010	API key dan secret payment gateway	Environment variable, backend server	Kritis	Jika bocor, dapat digunakan untuk membuat transaksi palsu atau memalsukan callback.
A-011	Hak akses admin / RBAC	P1.0 Verify Role, P4.0 Manajemen Admin	Kritis	Bypass otorisasi dapat menyebabkan user biasa mengakses fitur admin.
A-012	Audit log	Log sistem, P4.0 laporan dan monitoring	Tinggi	Dibutuhkan untuk pelacakan insiden, pembuktian aktivitas, dan investigasi keamanan.
A-013	Source code aplikasi	Repository GitHub	Tinggi	Source code dapat mengandung celah keamanan atau konfigurasi sensitif jika tidak dikelola dengan benar.
A-014	Callback payment gateway	P3.0 Pembayaran ↔ Payment Gateway	Kritis	Callback palsu dapat mengubah status pembayaran tanpa transaksi valid.
A-015	Endpoint login, booking, dan pembayaran	Backend API	Tinggi	Target utama brute force, spam request, injection, dan manipulasi parameter.

2.1.3 Security Requirements

Tabel 2.2 Security Requirements Sistem

ID	Kategori	Prioritas	Security Requirement
SR-01	Autentikasi	HARUS	Sistem HARUS melakukan autentikasi pengguna menggunakan email/username dan password sebelum pengguna dapat mengakses fitur booking, pembayaran, atau panel admin.
SR-02	Autentikasi	HARUS	Sistem HARUS menyimpan password menggunakan algoritma hashing yang aman seperti bcrypt atau Argon2 , bukan dalam bentuk plaintext.
SR-03	Autentikasi	HARUS	Sistem HARUS menerapkan mekanisme session authentication dengan cookie yang memiliki atribut HttpOnly dan Secure .
SR-04	Autentikasi	SEBAIKNYA	Sistem SEBAIKNYA menerapkan pembatasan percobaan login seperti rate limiting dan temporary lockout setelah beberapa kali gagal login.
SR-05	Otorisasi	HARUS	Sistem HARUS menerapkan Role-Based Access Control (RBAC) untuk membedakan hak akses antara tamu/pengguna dan admin.
SR-06	Otorisasi	TIDAK BOLEH	Sistem TIDAK BOLEH mengizinkan pengguna mengakses, mengubah, atau menghapus data booking milik pengguna lain tanpa otorisasi yang valid.
SR-07	Input Validation	HARUS	Sistem HARUS memvalidasi seluruh input dari pengguna,

			termasuk data login, registrasi, pencarian kamar, detail booking, dan pembayaran di sisi server.
SR-08	Input Validation	HARUS	Sistem HARUS menggunakan prepared statement atau parameterized query untuk seluruh operasi database.
SR-09	Input Validation	TIDAK BOLEH	Sistem TIDAK BOLEH hanya mengandalkan validasi di sisi client/browser untuk data penting seperti nominal pembayaran, ID booking, role user, dan status transaksi.
SR-10	Data Protection	HARUS	Sistem HARUS menggunakan protokol HTTPS/TLS untuk seluruh komunikasi antara user, web client, backend, dan layanan eksternal.
SR-11	Data Protection	HARUS	Sistem HARUS menjaga kerahasiaan file konfigurasi seperti .env agar tidak dapat diakses publik atau ikut masuk ke repository.
SR-12	Data Protection	TIDAK BOLEH	Sistem TIDAK BOLEH menampilkan data sensitif seperti password, token, API key, credential database, atau informasi kartu pembayaran pada URL, log, maupun pesan error.
SR-13	Payment Security	HARUS	Sistem HARUS melakukan verifikasi signature atau checksum pada setiap callback dari payment gateway.

SR-14	Payment Security	HARUS	Sistem HARUS memvalidasi nominal pembayaran, ID booking, status transaksi, dan timestamp/nonce sebelum memperbarui status pembayaran.
SR-15	Payment Security	TIDAK BOLEH	Sistem TIDAK BOLEH memperbarui status pembayaran hanya berdasarkan request dari client tanpa validasi dari backend dan payment gateway.
SR-16	Audit & Logging	HARUS	Sistem HARUS mencatat aktivitas penting seperti login, logout, booking, perubahan data booking, pembayaran, callback payment gateway, dan aktivitas admin.
SR-17	Audit & Logging	HARUS	Sistem HARUS menyimpan log dengan timestamp, user ID, jenis aktivitas, alamat IP, dan status aksi berhasil/gagal.
SR-18	Audit & Logging	TIDAK BOLEH	Sistem TIDAK BOLEH menyimpan password, token session, API key, atau data pembayaran sensitif secara utuh di dalam log.
SR-19	Availability	HARUS	Sistem HARUS menerapkan rate limiting pada endpoint login, booking, dan pembayaran untuk mengurangi risiko flood request.
SR-20	Availability	SEBAIKNYA	Sistem SEBAIKNYA menerapkan throttling atau pembatasan request untuk mencegah spam booking request.

SR-21	Database Security	HARUS	Sistem HARUS membatasi akses database hanya dari backend/server yang sah, bukan langsung dari client/browser.
SR-22	Database Security	HARUS	Sistem HARUS menggunakan akun database dengan hak akses minimum sesuai kebutuhan aplikasi.
SR-23	Error Handling	HARUS	Sistem HARUS menampilkan pesan error yang umum kepada pengguna tanpa membocorkan detail teknis seperti query SQL, path server, atau stack trace.
SR-24	File & Configuration Security	TIDAK BOLEH	Sistem TIDAK BOLEH menyimpan API key payment gateway, database password, atau secret token langsung di source code.
SR-25	Admin Security	HARUS	Sistem HARUS membatasi fitur manajemen admin hanya untuk akun dengan role admin yang telah terverifikasi.
SR-26	Admin Security	SEBAIKNYA	Sistem SEBAIKNYA mencatat seluruh perubahan data yang dilakukan admin, termasuk perubahan booking, transaksi, data kamar, dan data pengguna.

2.1.4 Definisi Stakeholder & Trust Boundary

Stakeholder

Tabel 2.3 Stakeholder Sistem

No	Stakeholder	Peran	Kepentingan Keamanan
----	-------------	-------	----------------------

1	Tamu/User	Pengguna akhir yang melakukan booking hotel	Kerahasiaan data pribadi, keamanan akun, keamanan transaksi pembayaran, keakuratan status booking
2	Admin	Pengelola data hotel dan transaksi	Integritas data kamar, booking, transaksi, serta pembatasan akses sesuai role
3	Payment Gateway	Pihak ketiga yang memproses pembayaran	Validitas transaksi, keamanan callback, perlindungan dari transaksi palsu
4	Developer	Tim pengembang sistem	Keamanan kode, manajemen dependency, konfigurasi server, dan pencegahan kebocoran secret
5	Database Server	Komponen penyimpanan data	Menjaga kerahasiaan, integritas, dan ketersediaan data user, booking, dan transaksi
6	Pemilik Hotel / Manajemen	Pihak yang menggunakan data laporan untuk operasional	Keakuratan laporan transaksi, perlindungan data bisnis, dan keandalan sistem

Trust Boundary

Tabel 2.4 Trust Boundary Sistem

Boundary ID	Antara Zona / Komponen	Risiko Utama	Mekanisme Keamanan
TB-01	User Browser ↔ Web Client	Penyadapan data, input berbahaya, manipulasi request	HTTPS/TLS, input validation, anti-XSS, rate limiting
TB-02	Web Client ↔ PHP Backend	Manipulasi parameter, bypass validasi client	Server-side validation, CSRF protection, session authentication

TB-03	Backend ↔ Proses Login/Register P1.0	Brute force, credential stuffing, spoofing	Password hashing, rate limiting, lockout, generic error message
TB-04	P1.0 Login/Register ↔ DS1 Db.Users	SQL Injection, kebocoran kredensial	Prepared statement, bcrypt/Argon2, akses database terbatas
TB-05	User ↔ P2.0 Booking Kamar	Manipulasi tanggal, ID kamar, harga, status booking	Validasi server-side, cek ketersediaan kamar, anti-tampering
TB-06	P2.0 Booking Kamar ↔ DS2 Db.Booking	Double booking, perubahan status tidak sah	Transaction control, prepared statement, validasi status booking
TB-07	User ↔ P3.0 Pembayaran	Manipulasi nominal pembayaran, request palsu	Server-side validation, redirect payment gateway, tidak menyimpan data kartu
TB-08	P3.0 Pembayaran ↔ Payment Gateway	Fake callback, replay attack, manipulasi status pembayaran	Signature verification, timestamp, nonce, whitelist IP
TB-09	P3.0 Pembayaran ↔ DS3 Db.Transaksi	Perubahan status transaksi tidak sah	Validasi callback, audit log, prepared statement
TB-10	Admin ↔ P4.0 Manajemen Admin	Bypass admin panel, privilege escalation	RBAC, session validation, audit trail
TB-11	P4.0 Manajemen Admin ↔ Database Booking/Transaksi	Manipulasi data oleh admin atau akun admin yang disalahgunakan	RBAC, validasi input, logging perubahan data

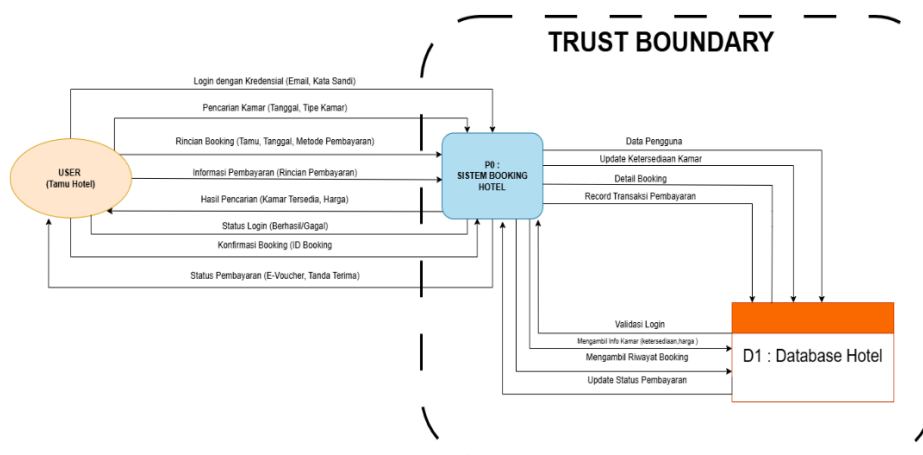
TB-12	Backend Server ↔ File Konfigurasi	Kebocoran .env, API key, database password	Environment variable, file permission, .gitignore, blok akses publik
TB-13	Semua Proses ↔ Log Sistem	Kebocoran data sensitif melalui log	Masking data, logging tanpa password/token/API key

2.2 Pembuatan DFD Level 0

Kelompok telah membuat DFD Level 0 sebagai gambaran umum aliran data pada sistem booking hotel. Diagram ini menunjukkan hubungan antara entitas eksternal User, proses utama Sistem Booking Hotel, dan penyimpanan data pada Database Hotel.

Pada DFD Level 0, alur data yang digambarkan meliputi proses login, pencarian kamar, pengiriman rincian booking, informasi pembayaran, hasil pencarian kamar, status login, konfirmasi booking, dan status pembayaran. Diagram ini membantu menjelaskan bagaimana pengguna berinteraksi dengan sistem secara umum sebelum proses dipecah lebih detail pada DFD Level 1.

DFD LEVEL 0 (GAMBARAN UMUM SISTEM)



Gambar 2.1 DFD Level 0 Hotel Booking Secure System

2.3 Pembuatan DFD Level 1

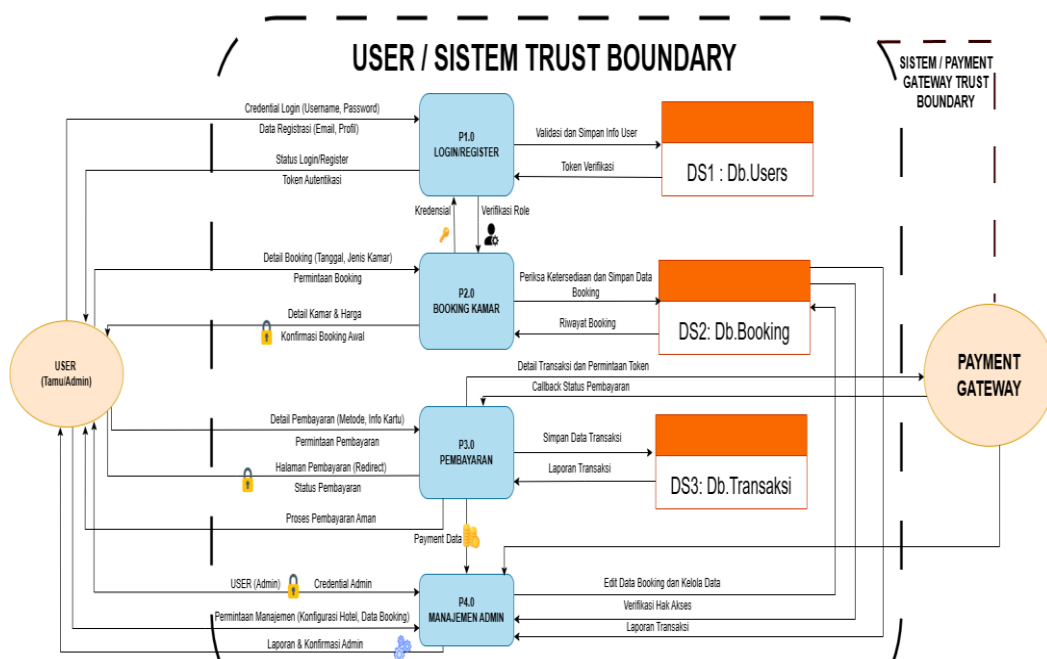
Setelah DFD Level 0 selesai, kelompok melanjutkan dengan membuat DFD Level 1. Diagram ini memecah proses utama sistem menjadi beberapa proses yang lebih spesifik, yaitu:

Tabel 2.5 Proses pada DFD Level 1

Kode Proses	Nama Proses	Keterangan
P1.0	Login/Register	Mengelola proses autentikasi dan registrasi pengguna
P2.0	Booking Kamar	Mengelola pencarian kamar, detail booking, dan konfirmasi booking
P3.0	Pembayaran	Mengelola proses pembayaran dan komunikasi dengan payment gateway
P4.0	Manajemen Admin	Mengelola data booking, laporan transaksi, dan verifikasi hak akses admin

DFD Level 1 juga menunjukkan penggunaan beberapa data store seperti Db.Users, Db.Booking, dan Db.Transaksi. Selain itu, diagram ini sudah memperlihatkan adanya User/System Trust Boundary dan System/Payment Gateway Trust Boundary, sehingga batas keamanan antara pengguna, sistem internal, dan sistem eksternal menjadi lebih jelas.

DFD LEVEL 1

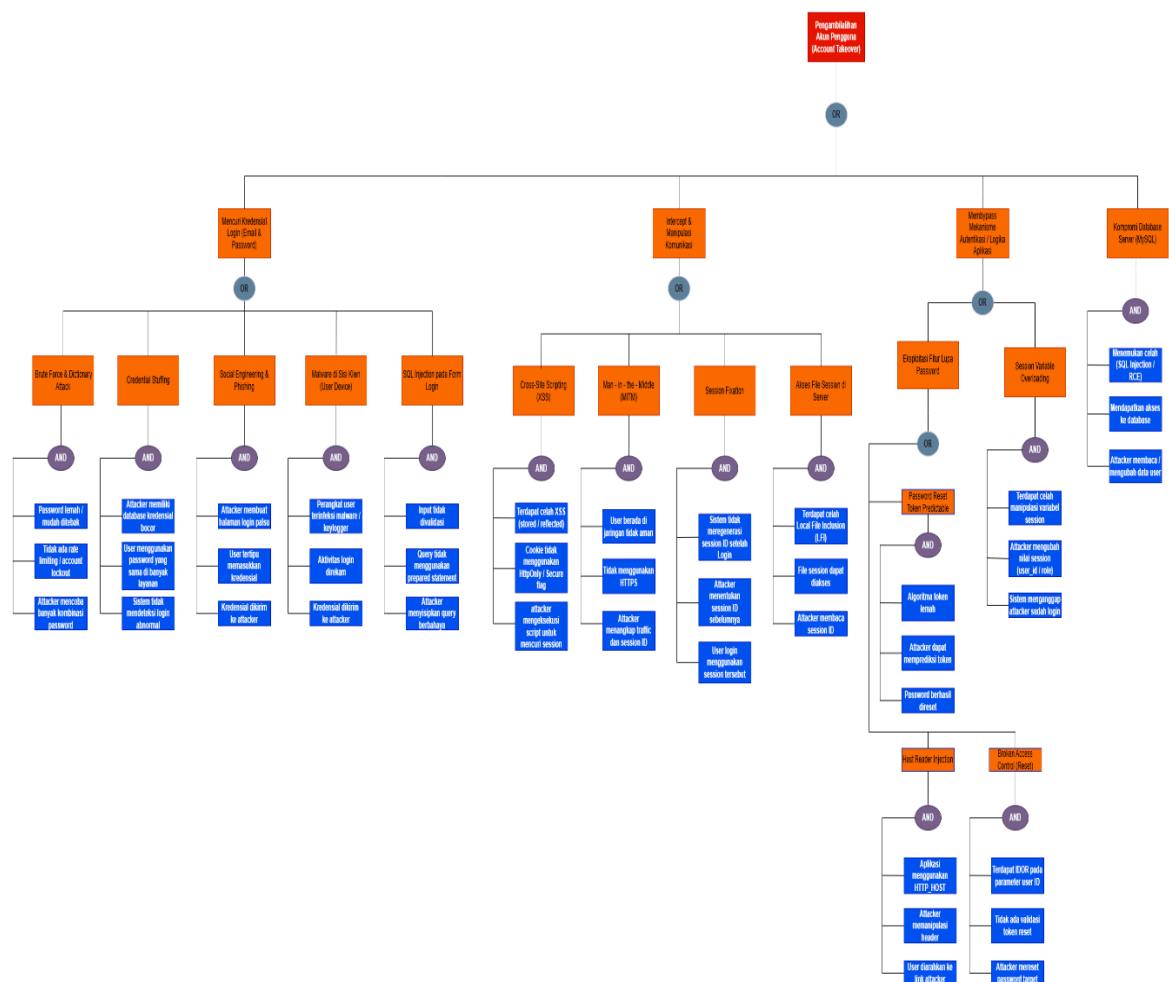


Gambar 2.2 DFD Level 1 Hotel Booking Secure System

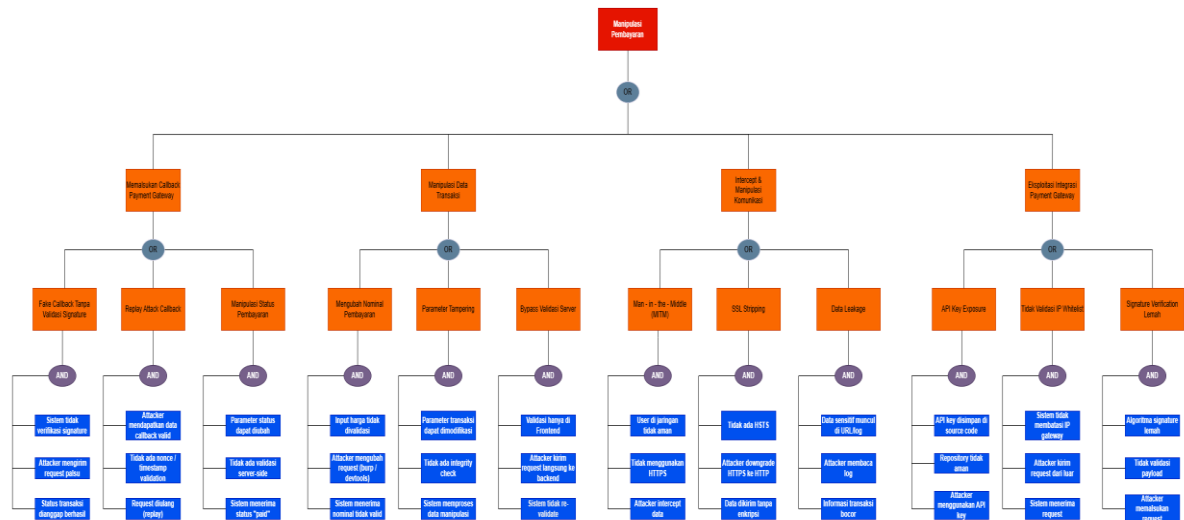
2.4 Penyusunan Attack Tree

Kelompok juga telah menyusun dua Attack Tree untuk mengidentifikasi kemungkinan serangan terhadap sistem. Attack Tree pertama berfokus pada ancaman terhadap proses pembayaran, seperti manipulasi callback payment gateway, manipulasi data transaksi, intersepsi komunikasi, serta eksploitasi integrasi payment gateway.

Attack Tree kedua berfokus pada ancaman terhadap sistem aplikasi, seperti pencurian kredensial login, SQL Injection, Cross-Site Scripting, session fixation, akses file sistem, file upload berbahaya, serta eksposur database server. Dengan adanya Attack Tree, kelompok dapat memahami jalur serangan yang mungkin digunakan oleh penyerang dan menentukan prioritas mitigasi.



Gambar 2.3 Attack Tree Pembayaran



Gambar 2.4 Attack Tree Sistem Aplikasi

Notes :

Untuk gambar lebih jelas (HD) sudah dimasukan ke dalam README serta di docs pada repository github

2.5 Analisis STRIDE

Kelompok telah melakukan analisis ancaman menggunakan metode STRIDE, yaitu Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, dan Elevation of Privilege. Berdasarkan dokumen STRIDE, total terdapat 23 ancaman yang telah diidentifikasi dan diklasifikasikan berdasarkan kategori STRIDE.

Hasil analisis menunjukkan bahwa terdapat 8 ancaman Critical, 11 ancaman High, dan 4 ancaman Medium. Hal ini menunjukkan bahwa mayoritas ancaman berada pada tingkat risiko tinggi, sehingga sistem membutuhkan mitigasi keamanan yang kuat terutama pada area login, pembayaran, session, database, dan backend.

Beberapa contoh ancaman yang telah diidentifikasi antara lain brute force terhadap kredensial login, credential stuffing, session hijacking, SQL Injection, manipulasi parameter booking, perubahan nominal pembayaran, manipulasi callback payment, password plaintext, kebocoran file .env, bypass RBAC, dan API key yang tersimpan di source code.

ID	STRIDE	ANCAMAN	KOMPONEN	RISK	MITIGASI
T-01	 SPOOFING	Kredensial hasil brute force	Login System	HIGH	Rate limiting + logout
T-02	 SPOOFING	Credential stuffing	Login System	HIGH	MFA + deteksi login
T-03	 SPOOFING	Phishing login page palsu	User	HIGH	HTTPS + edukasi user
T-04	 SPOOFING	Session hijacking (XSS)	Session	HIGH	HttpOnly + Secure cookie
T-05	 TAMPERING	SQL Injection form login	Backend	CRITICAL	Prepared statement
ID	STRIDE	ANCAMAN	KOMPONEN	RISK	MITIGASI
T-06	 TAMPERING	Manipulasi parameter booking	Booking Sys	HIGH	Validasi server-side
T-07	 TAMPERING	Perubahan nominal bayar	Payment	CRITICAL	Integrity check
T-08	 TAMPERING	Parameter tampering API	API	HIGH	Input sanitization
T-09	 TAMPERING	Manipulasi callback payment	Payment GW	CRITICAL	Signature verification
T-10	 REPUDIATION	User menyangkal transaksi	Payment	MEDIUM	Logging + timestamp

ID	STRIDE	ANCAMAN	KOMPONEN	RISK	MITIGASI
T-11	 REPUDIATION	Admin menyangkal data	Admin Panel	MEDIUM	Audit trail
T-12	 INFO DISCLOSURE	Password plaintext	Database	CRITICAL	bcrypt hashing
T-13	 INFO DISCLOSURE	Kebocoran via MitM	Session	HIGH	HTTPS enforcement
T-14	 INFO DISCLOSURE	Kebocoran file .env	Server	CRITICAL	Env config protection
T-15	 INFO DISCLOSURE	Data sensitif di URL/Log	Server	MEDIUM	Masking policy

ID	STRIDE	ANCAMAN	KOMPONEN	RISK	MITIGASI
T-16	⚠ DENIAL OF SERVICE	Flood login request	Server	HIGH	Rate limiting
T-17	⚠ DENIAL OF SERVICE	Spam booking request	Backend	MEDIUM	Throttling
T-18	⬆ ELEVATION OF PRIVILEGE	Bypass RBAC fitur admin	Admin Panel	HIGH	RBAC enforcement
T-19	⬆ ELEVATION OF PRIVILEGE	Session var overloading	Session	CRITICAL	Session validation
T-20	⬆ ELEVATION OF PRIVILEGE	Bypass reset token	Backend	CRITICAL	Secure token gen
ID	STRIDE	ANCAMAN	KOMPONEN	RISK	MITIGASI
T-21	✂ TAMPERING	Replay attack callback	Payment	HIGH	Timestamp & Nonce
T-22	👤 SPOOFING	Fake callback PG	Payment	CRITICAL	IP Whitelist + Sign
T-23	🔑 INFO DISCLOSURE	API key di source code	Server	CRITICAL	Env variables

Gambar 2.5 Hasil Analisis STRIDE

2.6 Perancangan Arsitektur Sistem

Kelompok telah membuat rancangan arsitektur sistem yang memetakan komponen utama ke dalam beberapa zona, yaitu Public Zone, Trusted Zone, dan External Zone. Komponen yang termasuk dalam arsitektur adalah User, Web Client, PHP Backend, MySQL Database, dan Payment Gateway.

Arsitektur sistem juga mencantumkan protokol keamanan yang digunakan, seperti HTTPS, session authentication, input validation, dan signature verification. Pada dokumen arsitektur, web client dikategorikan sebagai bagian dari public zone karena berjalan di sisi browser dan tidak dapat sepenuhnya dipercaya, sehingga validasi utama tetap harus dilakukan di sisi backend.

Selain itu, rancangan arsitektur juga menjelaskan beberapa keputusan keamanan, seperti penggunaan session-based authentication dengan cookie HttpOnly dan Secure, bcrypt untuk hashing password, prepared statement untuk mencegah SQL Injection, HTTPS/TLS untuk keamanan komunikasi, serta signature verification pada callback payment gateway. Berikut



Gambar 2.6 Arsitektur Sistem Hotel Booking Secure System

2.7 Persiapan Repository GitHub

Kelompok telah menyiapkan repository GitHub sebagai tempat penyimpanan dokumentasi dan pengembangan proyek. Struktur repository sudah mulai dirapikan dengan pembagian folder seperti:

```
backend/
frontend/
docs/
├── 01_report/
├── 02_srs/
├── 03_threat_modeling/
│   ├── Attack_Tree/
│   ├── DFD/
│   ├── Mitigation/
│   └── STRIDE/
└── 04_Architecture/
```

Struktur folder tersebut sudah cukup baik karena memisahkan kode program, dokumen SRS, DFD, Attack Tree, STRIDE, mitigasi, dan arsitektur sistem. Hal ini juga sesuai dengan arahan minggu pertama yang menekankan pentingnya repository Git yang rapi, dokumentasi awal, serta pembagian deliverable proyek.

BAB III

PENUTUP

3.1 Kesesuaian dengan Target Minggu 1

Berdasarkan materi pendukung final project, deliverable minggu pertama mencakup diagram arsitektur, dokumen perencanaan proyek, tabel pembagian tugas dan estimasi biaya, repository Git dengan README.md, serta presentasi singkat untuk review dosen.

Berikut ceklis evaluasi progress kelompok:

Tabel 3.1 Ceklis Evaluasi Progress Minggu 1

No	Deliverable Minggu 1	Status	Keterangan
1	Dokumen SRS-Sec	Selesai	Berisi kebutuhan sistem dan kebutuhan keamanan
2	DFD Level 0	Selesai	Menjelaskan gambaran umum aliran data sistem
3	DFD Level 1	Selesai	Menjelaskan proses login/register, booking, pembayaran, dan admin
4	Attack Tree	Selesai	Terdapat dua attack tree untuk skenario ancaman berbeda
5	STRIDE Threat Modeling	Selesai	Mengidentifikasi 23 ancaman keamanan
6	Arsitektur Sistem	Selesai	Memuat zona sistem, komponen utama, dan protokol keamanan
7	Repository GitHub	Selesai	Struktur folder sudah dibuat dan dokumen sudah dikelompokkan
8	Tabel Pembagian Tugas	Selesai	Ditambahkan di README
9	README.md	Selesai	Memuat deskripsi proyek, anggota, struktur folder, dan progres

3.2 Kendala yang Dihadapi

Selama pengerjaan minggu pertama, kendala utama yang dihadapi adalah menyusun dokumentasi keamanan agar selaras antara SRS, DFD, Attack Tree, STRIDE, dan arsitektur sistem. Setiap dokumen harus saling berkaitan, sehingga ancaman yang muncul pada STRIDE dan Attack Tree harus sesuai dengan alur data serta trust boundary pada DFD.

Selain itu, kelompok juga perlu memastikan bahwa repository GitHub memiliki struktur folder yang rapi dan mudah dipahami. Hal ini penting karena repository akan menjadi tempat utama penyimpanan dokumen dan pengembangan sistem pada minggu-minggu berikutnya.

3.3 Rencana Tindak Lanjut Minggu Berikutnya

Pada minggu berikutnya, kelompok akan melanjutkan pekerjaan ke tahap implementasi awal dan penyempurnaan dokumen. Beberapa rencana tindak lanjut yang akan dilakukan adalah:

1. Melengkapi README.md pada repository GitHub untuk progress minggu – minggu selanjutnya
2. Mulai membuat struktur untuk backend dan frontend.
3. Menyesuaikan implementasi sistem dengan requirement keamanan pada SRS-Sec.
4. Melakukan commit berkala ke repository GitHub agar progress terdokumentasi dengan baik.

3.4 Kesimpulan

Berdasarkan progress minggu pertama, kelompok telah berhasil menyelesaikan tahap perencanaan dan analisis awal untuk proyek Hotel Booking Secure System. Dokumen yang telah dibuat meliputi SRS-Sec, DFD Level 0, DFD Level 1, Attack Tree, STRIDE Threat Modeling, dan arsitektur sistem. Seluruh dokumen tersebut menjadi dasar penting untuk memastikan sistem tidak hanya berjalan secara fungsional, tetapi juga memperhatikan aspek keamanan sejak tahap perancangan.

Hasil analisis STRIDE menunjukkan bahwa sistem memiliki beberapa ancaman dengan tingkat risiko tinggi dan kritis, terutama pada bagian login, pembayaran, session, backend, dan database. Oleh karena itu, mitigasi seperti HTTPS/TLS, password hashing menggunakan bcrypt, RBAC, prepared statement, session security, input validation, dan signature verification menjadi bagian penting dalam rancangan sistem.

Secara keseluruhan, progress minggu pertama sudah cukup baik dan sesuai dengan arah pengerjaan awal proyek. Namun, kelompok masih perlu melengkapi beberapa bagian seperti README.md, pembagian tugas anggota, estimasi biaya cloud, serta dokumentasi mitigasi agar deliverable minggu pertama menjadi lebih lengkap dan siap untuk dikembangkan pada minggu berikutnya.

3.5 Lampiran

Link Github: <https://github.com/hesselji/hotel-booking-secure-system>